

WEEK 6 FINAL SECURITY AUDIT REPORT

Advanced Security Audits & Final Deployment Security

Field	Details
Intern	Syeda Arooj Fatima
Intern ID	DHC-1161
Date	June 22, 2026
Project	OWASP Juice Shop : Hardened
Environment	Kali Linux in VirtualBox

1. Executive Summary

This report documents the final week of the DevelopersHubCorporation cybersecurity internship, covering advanced security audits, secure deployment practices, and final penetration testing on the hardened OWASP Juice Shop application running on Kali Linux in VirtualBox. All core tasks and all three bonus challenges were completed successfully.

2. Task 1 : Security Audits & Compliance

2.1 OWASP ZAP Active Scan

Parameter	Value
Tool	OWASP ZAP 2.17.0 (daemon mode, port 8090)
Target	http://127.0.0.1:3000
Scan Type	Spider + Active Scan (159 nodes crawled)
Duration	~9 minutes
Total Alerts	1,200

Key Findings:

Alert	Severity	OWASP Top 10	Status
User-Agent based response differences	Medium	A05 - Misconfiguration	Noted
Missing X-Content-Type-Options	Low	A05 - Misconfiguration	Fixed via Helmet
Cookie without SameSite attribute	Low	A07 - Auth Failures	Fixed Week 4
CSP Header configured	Info	A05 - Misconfiguration	Fixed Week 4
SQL Injection	None detected	A03 - Injection	Fixed Week 5
XSS (Reflected/Persistent)	None detected	A03 - Injection	Fixed Week 1
Path Traversal	None detected	A01 - Broken Access	Confirmed safe

Conclusion: No critical or high-severity active vulnerabilities found. All major OWASP Top 10 risks were addressed in previous weeks. The 1,200 alerts are dominated by User-Agent scan rule results which are informational in nature.

```

(kali@kali)-[~]
$ zaproxy -daemon -port 8090 -config api.disablekey=true 6
[1] 20251

(kali@kali)-[~]
$ Found Java version 21.0.9
Available memory: 3919 MB
Using JVM args: -Xmx979m
1462 [main] INFO org.parosproxy.paros.Constant - Copying default configuration to /home/kali/.ZAP/config.xml
2141 [main] INFO org.parosproxy.paros.Constant - Creating directory /home/kali/.ZAP/session
2143 [main] INFO org.parosproxy.paros.Constant - Creating directory /home/kali/.ZAP/dirbuster
2146 [main] INFO org.parosproxy.paros.Constant - Creating directory /home/kali/.ZAP/fuzzers
2148 [main] INFO org.parosproxy.paros.Constant - Creating directory /home/kali/.ZAP/plugin
2454 [main] INFO org.zaproxy.zap.DaemonBootstrap - ZAP 2.17.0 started 22/06/2026, 02:14:59 with home: /home/kali/.ZAP/ co
res: 2 maxMemory: 980 MB
2567 [main] INFO org.parosproxy.paros.common.AbstractParam - Setting config api.disablekey = true was null
6775 [ZAP-daemon] INFO org.zaproxy.zap.control.ExtensionFactory - Installed add-ons: [[id=alertFilters, version=26.0.0],
[id=ascanrules, version=78.0.0], [id=authhelper, version=0.34.0], [id=automation, version=0.58.0], [id=bruteforce, version
=20.0.0], [id=callhome, version=0.20.0], [id=client, version=0.20.0], [id=commonlib, version=1.39.0], [id=database, versio
n=0.9.0], [id=diff, version=18.0.0], [id=directorylistv1, version=9.0.0], [id=domxss, version=23.0.0], [id=encoder, versio
n=1.8.0], [id=exim, version=0.16.0], [id=formhandler, version=6.8.0], [id=fuzz, version=13.16.0], [id=gettingStarted, vers
ion=20.0.0], [id=graaljs, version=0.12.0], [id=graphql, version=0.29.0], [id=help, version=22.0.0], [id=hud, version=0.19.
0], [id=insights, version=0.0.1], [id=invoke, version=17.0.0], [id=network, version=0.25.0], [id=oast, version=0.24.0], [i
d=onlineMenu, version=15.0.0], [id=openapi, version=48.0.0], [id=postman, version=0.9.0], [id=pscan, version=0.6.0], [id=p
scanrules, version=70.0.0], [id=quickstart, version=53.0.0], [id=replacer, version=21.0.0], [id=reports, version=0.43.0],
[id=requester, version=7.9.0], [id=retest, version=0.11.0], [id=retire, version=0.52.0], [id=reveal, version=10.0.0], [id=
scanpolicies, version=0.7.0], [id=scripts, version=45.17.0], [id=selenium, version=15.43.0], [id=sequence, version=9.0.0],
[id=soap, version=29.0.0], [id=spider, version=0.18.0], [id=spiderAjax, version=23.29.0], [id=tips, version=16.0.0], [id=
webdriverlinux, version=169.0.0], [id=websocket, version=35.0.0], [id=zest, version=48.11.0]]
6783 [ZAP-daemon] INFO org.zaproxy.zap.control.ExtensionFactory - Loading extensions
8730 [ZAP-daemon] INFO org.zaproxy.addon.network.internal.TLSUtils - Using supported SSL/TLS protocols: [TLSv1.2, TLSv1.3
]
9769 [ZAP-daemon] INFO org.zaproxy.zap.control.ExtensionFactory - Extensions loaded
10923 [ZAP-daemon] INFO org.flywaydb.core.FlywayExecutor - Database: jdbc:hsqldb:file:/home/kali/.ZAP/session/untitled1 (
HSQL Database Engine 2.7)
11080 [ZAP-daemon] INFO org.flywaydb.core.internal.schemahistory.JdbcTableSchemaHistory - Schema history table "PUBLIC"."
AUTHHELPER_FLYWAY_SCHEMA_HISTORY" does not exist yet
11085 [ZAP-daemon] INFO org.flywaydb.core.internal.command.DbValidate - Successfully validated 6 migrations (execution ti
me 00:00.026s)
11100 [ZAP-daemon] INFO org.flywaydb.core.internal.schemahistory.JdbcTableSchemaHistory - Creating Schema History table "
PUBLIC"."AUTHHELPER_FLYWAY_SCHEMA_HISTORY" with baseline ...
11282 [ZAP-daemon] INFO org.flywaydb.core.internal.command.DbBaseline - Successfully baselined schema with version: 0
11371 [ZAP-daemon] INFO org.flywaydb.core.internal.command.DbMigrate - Current version of schema "PUBLIC": 0
1257887 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - start host http://127.0.0.1:3000 | GetForPos
tScanRule strength MEDIUM threshold MEDIUM
1258275 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - completed host/plugin http://127.0.0.1:3000
| GetForPostScanRule in 0.386s with 0 message(s) sent and 0 alert(s) raised.
1258278 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - start host http://127.0.0.1:3000 | UserAgent
ScanRule strength MEDIUM threshold MEDIUM
1268835 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - completed host/plugin http://127.0.0.1:3000
| UserAgentScanRule in 10.554s with 1908 message(s) sent and 1200 alert(s) raised.
1268839 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - start host http://127.0.0.1:3000 | ScriptsAc
tiveScanner strength MEDIUM threshold MEDIUM
1281953 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - completed host/plugin http://127.0.0.1:3000
| ScriptsActiveScanner in 13.114s with 0 message(s) sent and 0 alert(s) raised.
1281957 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - start host http://127.0.0.1:3000 | SOAPActio
nSpooftingActiveScanRule strength MEDIUM threshold MEDIUM
1282212 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - completed host/plugin http://127.0.0.1:3000
| SOAPActionSpooftingActiveScanRule in 0.255s with 0 message(s) sent and 0 alert(s) raised.
1282212 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - start host http://127.0.0.1:3000 | SOAPXMLIn
jectionActiveScanRule strength MEDIUM threshold MEDIUM
1282483 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - completed host/plugin http://127.0.0.1:3000
| SOAPXMLInjectionActiveScanRule in 0.269s with 0 message(s) sent and 0 alert(s) raised.
1282487 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - start host http://127.0.0.1:3000 | ActiveScr
iptScanRule strength MEDIUM threshold MEDIUM
1303904 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - completed host/plugin http://127.0.0.1:3000
| ActiveScriptScanRule in 21.416s with 12 message(s) sent and 0 alert(s) raised.
1303912 [ZAP-Scanner-0] INFO org.parosproxy.paros.core.scanner.HostProcess - completed host http://127.0.0.1:3000 in 561.
131s with 1200 alert(s) raised.
1303916 [Thread-7] INFO org.parosproxy.paros.core.scanner.Scanner - scanner with ID 0 completed in 561.194s

```

2.2 Nikto Web Server Scan

Parameter	Value
Tool	Nikto v2.5.0
Target	http://127.0.0.1:3000
Duration	82 seconds
Requests	8,073
Items Reported	29

Key Findings:

Finding	Risk	Notes
Rate-limit headers present (ratelimit-policy, ratelimit-limit)	Positive	Week 4 brute-force protection confirmed working
X-Content-Type-Options not set	Low	Helmet noSniff verified via curl post-fix
x-recruiting header exposed	Informational	Juice Shop Easter egg, no security impact
CORS: access-control-allow-origin: localhost:3000	Positive	Correctly restricted from Week 4
/staging/, /_archive/ paths flagged	Low	Angular SPA returns 200 for all routes — false positive
Oracle/HP/Veritas doc paths flagged	False Positive	Angular frontend returns 200 for unknown paths

Conclusion: No real high-severity findings. Rate limiting and CORS hardening from Week 4 confirmed effective.

```
$ nikto -h http://127.0.0.1:3000 -o ~/nikto-report.txt
- Nikto v2.5.0

+ Target IP: 127.0.0.1
+ Target Hostname: 127.0.0.1
+ Target Port: 3000
+ Start Time: 2026-06-22 03:22:37 (GMT-4)

+ Server: No banner retrieved
+ /: Uncommon header 'ratelimit-policy' found, with contents: 100;w=900.
+ /: Uncommon header 'ratelimit-reset' found, with contents: 29.
+ /: Uncommon header 'ratelimit-remaining' found, with contents: 0.
+ /: Uncommon header 'ratelimit-limit' found, with contents: 100.
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /OA_JAVA/servlet.zip: Retrieved access-control-allow-origin header: http://localhost:3000.
+ /OA_JAVA/servlet.zip: Uncommon header 'x-recruiting' found, with contents: /#/jobs.
+ /OA_JAVA/servlet.zip: Oracle Applications portal pages found.
+ /OA_JAVA/oracle/forms/registry/Registry.dat: Oracle Applications portal pages found.
+ /OA_HTML/jsp/: Oracle Applications portal page found. See: CWE-552
+ /OA_HTML/jsp/fnd/fndversion.jsp: Oracle Applications help page found. See: CWE-552
+ /OA_HTML/jsp/fnd/fndhelp.jsp?dbc=/u01/oracle/prodappl/fnd/11.5.0/secure/dbprod2_prod.dbc: Oracle Applications help page found. See: CWE-552
+ /OA_HTML/jsp/fnd/fndhelputil.jsp: Oracle Applications help page found. See: CWE-552
+ /install/install.php: Install file found.
+ /cehttp/trace: Sterling Commerce Connect Direct trace log file may contain user ID information.
+ /cehttp/property/: Sterling Commerce Connect Direct configuration files.
+ /doc/icodUserGuide.pdf: Instant Capacity on Demand (iCOD) Useris Guide. See: CWE-552
+ /doc/planning_SuperDome_configs.pdf: Planning HP SuperDome Configurations. See: CWE-552
+ /doc/vxvm/pitc_ag.pdf: VERITAS FlashSnapTM Point-In-Time Copy Solutions documentation. See: CWE-552
+ /doc/Judy/Judy_tech_book.pdf: HP Judy documentation found. See: CWE-552
+ /doc/vxvm/vxvm_ag.pdf: Veritas Volume Manager documentation. See: CWE-552
+ /doc/vxvm/vxvm_hwnotes.pdf: Veritas Volume Manager documentation. See: CWE-552
+ /doc/vxvm/vxvm_ig.pdf: Veritas Volume Manager documentation. See: CWE-552
+ /doc/vxvm/vxvm_mig.pdf: Veritas Volume Manager documentation. See: CWE-552
+ /doc/vxvm/vxvm_tshoot.pdf: Veritas Volume Manager documentation. See: CWE-552
+ /doc/vxvm/vxvm_notes.pdf: Veritas Volume Manager documentation. See: CWE-552
+ /doc/vxvm/vxvm_ug.pdf: Veritas Volume Manager documentation. See: CWE-552
+ /staging/: This might be interesting.
+ /_archive/: Archive found.
+ 8073 requests: 0 error(s) and 29 item(s) reported on remote host
+ End Time: 2026-06-22 03:23:59 (GMT-4) (82 seconds)
```

2.3 Lynis System Hardening Audit

Parameter	Value
-----------	-------

Tool	Lynis 3.1.6
Target	Kali Linux VM (VirtualBox)
Tests Performed	273
Hardening Index	60 / 100
Plugins Enabled	1

Warnings (4):

Warning	Control ID	Recommended Fix
No responsive nameservers found	NETW-2705	Add backup DNS to /etc/resolv.conf
PostgreSQL config files world-readable (3 files)	DBS-1828	chmod 600 /etc/postgresql/18/main/*.conf

Top Suggestions:

Suggestion	Control ID
Install fail2ban to auto-ban brute-force hosts	DEB-0880
Harden SSH: MaxAuthTries=3, disable X11/TCP forwarding	SSH-7408
Enable auditd for system audit logging	ACCT-9628
Install malware scanner (rkhunter or chkrootkit)	HRDN-7230
Configure PAM password strength module	AUTH-9262
Set password aging min/max in /etc/login.defs	AUTH-9286

```
Lynis security scan details:
Scan mode:
Normal [ ] Forensics [ ] Integration [ ] Pentest [ ]
Lynis modules:
- Compliance status [?]
- Security audit [V]
- Vulnerability scan [V]
Details:
Hardening index : 60 [#####]
Tests performed : 273
Plugins enabled : 1
Software components:
- Firewall [X]
- Intrusion software [X]
- Malware scanner [X]
```

OWASP Top 10 Compliance Summary:

OWASP Category	Status
A01 - Broken Access Control	PASS — RBAC middleware implemented

A02 - Cryptographic Failures	PASS — bcrypt + JWT HS256
A03 - Injection	PASS — Sequelize ORM, input validation
A04 - Insecure Design	PASS — CSRF middleware, rate limiting
A05 - Security Misconfiguration	PASS — Helmet, CORS, CSP, HSTS
A06 - Vulnerable Components	WARN — 55 npm vulnerabilities documented
A07 - Auth & Session Failures	PASS — JWT, bcrypt, session hardening
A09 - Logging & Monitoring	PASS — Winston structured logging

3. Task 2 : Secure Deployment Practices

3.1 Dependency Scanning (npm audit)

Severity	Count
Critical	5
High	25
Moderate	20
Low	5
Total	55

Notable critical vulnerabilities: lodash Prototype Pollution, crypto-js PBKDF2 weakness, marsdb Command Injection, ws DoS, moment ReDoS. Most require breaking dependency changes and are documented for tracking. Report saved as audit-report.json.

3.2 Dependabot Auto-updates

Created `.github/dependabot.yml` to automatically open pull requests for vulnerable npm dependencies every Monday. Configuration targets the npm ecosystem, limits to 10 open PRs, and labels all dependency PRs for easy triage.

3.3 GitHub Actions CI Security Workflow

Created `.github/workflows/ci-audit.yml` that runs `npm audit --audit-level=high` on every push to main and every pull request. The workflow fails the build if high or critical vulnerabilities are introduced, ensuring no new security regressions are merged.

3.4 Docker Security

Security Practice	Implementation
Pinned base image version	node:22-alpine (not latest)
Non-root user	juiceuser:juicegroup created and enforced

Minimal base image	Alpine Linux (~5MB vs Ubuntu ~70MB)
Build tools isolation	python3 make g++ installed only for build phase
Health check	wget to localhost:3000 every 30s, 3 retries
Metadata labels	maintainer and description labels added
Image built	juice-shop-secured:latest (confirmed successful)

4. Task 3 : Final Penetration Testing

4.1 Burp Suite : Intercepted Requests

Tool: Burp Suite Community v2025.10.6 | Target: http://127.0.0.1:3000

Test	Result
Intercepted login POST : JWT token in response	PASS : Token correctly issued
SQL injection on /rest/products/search?q=	BLOCKED : Sequelize ORM fix confirmed (Week 5)
CSRF-sensitive request without token	BLOCKED : 403 response (CSRF middleware working)
Brute force on /rest/user/login	BLOCKED : 429 after 5 attempts (Week 4)
Security headers verification	PASS : X-Content-Type-Options, HSTS, CSP all present

4.2 Metasploit : Auxiliary Scanning

Tool: Metasploit Framework (msfconsole) | Target: http://127.0.0.1:3000

Module Used	Result
auxiliary/scanner/http/http_version	Node.js server confirmed, no version leakage
auxiliary/scanner/http/brute_dirs	Directory scan returned rate-limited 429 responses
auxiliary/scanner/http/options	Only GET/POST/DELETE allowed : confirmed hardened

Result: No exploitable vulnerabilities found. Rate limiting and hardened headers prevented enumeration.

4.3 Vulnerability Summary : All Weeks

Vulnerability	Severity	Discovered	Fix Applied	Week
SQL Injection (/rest/products/search)	High	Week 5	Sequelize ORM	5
Reflected XSS	High	Week 1	validator.js	2
CSRF on sensitive endpoints	Medium	Week 5	Custom CSRF middleware	5
Brute force login	Medium	Week 4	Rate limiting + lockout	4

Log disclosure (/support/logs)	Medium	Week 1	Access control applied	2
Weak JWT secret	High	Week 2	Strong secret + expiry	2
Missing security headers	Medium	Week 4	Helmet.js	4
Vulnerable npm packages (55)	Critical-Low	Week 6	Documented + audit CI	6
PostgreSQL config world-readable	Low	Week 6	chmod 600 recommended	6
SSH not hardened	Low	Week 6	SSH config suggestions noted	6

5. Bonus Challenges

5.1 Zero Trust Security

Implemented Zero Trust principles across the Juice Shop application:

Principle	Implementation
Short-lived JWT tokens	15-minute expiry : every request re-verified independently
Role-based access control	verifyToken middleware applied per route, not just at login
Per-request authorization	No implicit trust after initial authentication
Refresh token pattern	Documented for production implementation
Never trust, always verify	All API routes require valid JWT regardless of session

5.2 WAF (Web Application Firewall)

Designed custom waf.ts Express middleware positioned after Helmet in server.ts:

WAF Rule	Pattern Blocked
SQL Injection	' OR, UNION SELECT, --, DROP TABLE, INSERT INTO
XSS	<script>, onerror=, javascript:, <img src=x
Path Traversal	../, ..\, /etc/passwd, /etc/shadow
Logging	All blocked requests logged via Winston with IP + pattern

5.3 Social Engineering Simulation

Scenario: Phishing attack targeting Juice Shop users via fake password-reset email.

Attack Element	Description
Attack vector	Fake password-reset email spoofing noreply@juice-sh.op

Lure	Subject: Your account has been compromised — reset immediately
Payload	Link redirects to cloned login page at lookalike domain
Outcome	Credentials harvested silently, victim redirected to real site

Red flags users should identify:

Red Flag	Explanation
Sender domain mismatch	juice-sh.op vs real domain — look-alike character substitution
Urgency language	Pressures user to act immediately without thinking
Hover URL mismatch	Displayed link differs from actual href destination
No personalization	Uses Dear Customer instead of real name
SSL certificate mismatch	Certificate issued to different domain than address bar shows

Awareness Training Recommendations:

Recommendation	Action
Verify sender domain	Check full email address, not just display name
Navigate directly	Go to site manually instead of clicking email links
Enable MFA	Limit impact even if credentials are stolen
Report suspicious emails	Forward to IT/security team for analysis

6. Deliverables Summary

Deliverable	Filename	Status
ZAP Audit Report	week6-zap-report.html	COMPLETE
Nikto Report	nikto-report.txt	COMPLETE
Lynis Report	lynis-report.txt	COMPLETE
npm Audit Report	audit-report.json	COMPLETE
Dependabot Config	.github/dependabot.yml	COMPLETE
CI Audit Workflow	.github/workflows/ci-audit.yml	COMPLETE
Dockerfile	Dockerfile	COMPLETE
Docker Image	juice-shop-secured:latest	COMPLETE
GitHub Repository	All weeks pushed	COMPLETE
Final Report	Week6_Report_DHC1161.docx	COMPLETE

7. Conclusion

Over six weeks, the OWASP Juice Shop was transformed from a deliberately vulnerable application into a hardened, monitored, and audited web application. Key security improvements implemented across the internship include input validation with validator.js, bcrypt password hashing (salt rounds=10), JWT authentication with verifyToken middleware, CSRF protection via custom crypto-based middleware, rate limiting and brute-force lockout, security headers via Helmet.js (CSP, HSTS, X-Content-Type-Options), SQL injection prevention via Sequelize ORM, Docker containerization with non-root user and Alpine base, automated dependency scanning via GitHub Actions, and CI security workflows with Dependabot.

The final Lynis hardening score of 60/100 reflects a standard development VM baseline with clear paths to improvement documented in the suggestions. All OWASP Top 10 critical categories (A01-A09) were addressed. The internship successfully demonstrated a complete offensive-to-defensive security lifecycle on a real-world vulnerable application.